

CI Gates สำหรับ AI-Assisted และ Agent-Authored Changes

Complementary control ต่อ POL-AI-AUP-002 · ฉบับภาษาไทย

Version: 1.0

Owner: Platform / DevSecOps + AI Governance Lead

วัตถุประสงค์: บังคับ provenance, constitution compliance, dependency hygiene และ risk-tiered review ใน merge pipeline

1. Required Labels (Provenance)

ทุก pull request ต้องมี label เพียงหนึ่งอันดังนี้:

Label	ความหมาย
provenance:human	เขียนโดยมนุษย์ทั้งหมดโดยไม่มี AI assistance ที่มีสาระสำคัญ
provenance:ai-assisted	มนุษย์เป็นผู้เขียนหลัก มี AI ช่วย draft หรือ completion อย่างมีสาระ
provenance:agent	เปิดหรือเขียนส่วนใหญ่โดย autonomous agent

การติด label เท็จหรือขาด label เป็นการละเมิด policy และ block merge

2. AI Percentage Gate

คำนวณจากสัดส่วนของ changed lines ที่ attributed ไปยัง AI (ผ่าน commit trailer, session metadata หรือ approved detection tooling)

เงื่อนไข	Action
AI-attributed code $\geq$ 15% และมี high-severity scanner finding (SAST/SCA/secret)	Auto-reject จนกว่าจะ remediate
AI-attributed code $\geq$ 40%	ต้องมี second human reviewer
AI-attributed code ที่แตะ auth, PII, payments หรือ infra	ต้องมี traceability note + elevated review

3. Constitution Compliance Gate

สำหรับ change ที่ติด label provenance:ai-assisted หรือ provenance:agent:

Check	Required Evidence / Enforcement
มี root-cause analysis (What / How / Why)	ต้องปรากฏใน PR description หรือ linked comment ก่อนมีการแก้ไขโค้ด
Scope จำกัดเฉพาะไฟล์ที่จำเป็นต่อ root cause	Diff ต้องไม่มี unrelated file deletion หรือ rename
ไม่มี invented variable / config value	variable หรือ config key ใหม่ต้องได้รับการ explicit confirmation จาก human ใน PR thread
ยึด minimal change principle	Reviewer (หรือ automated diff-size heuristic) อาจ reject pure drive-by refactor
Multi-agent safety	หากมีหลาย agent แตะไฟล์เดียวกัน harness ต้องแสดง sequential hand-off หรือ lock มิฉะนั้น fail

ความล้มเหลวของ constitution check ใด ๆ จะ block merge จนกว่าจะแก้ไขหรือได้รับ explicit waiver จาก AI Governance Lead (time-boxed exception)

4. Dependency & Version Pin Gate

Rule	Enforcement
การเพิ่ม อัปเดต หรือลบ runtime หรือ build dependency ใด ๆ	ต้องประกาศใน PR body โดยระบุ package name, old version (ถ้ามี), new version และ rationale
การเปลี่ยนแปลง lockfile	ต้องมาพร้อมกับประกาศข้างต้น
Major version bump หรือ new direct dependency	ต้องมี human confirmation comment ใน PR
การนำ package ที่มี known critical CVE หรือ incompatible license เข้ามา	Auto-reject

Automated check ที่แนะนำ: parse package.json / go.mod / Cargo.toml / requirements.txt ฯลฯ + lockfile diff แล้ว fail หากมีการเปลี่ยนแปลงที่ไม่ได้ประกาศ

5. Risk-Tiered Review SLAs

Tier	ตัวอย่าง	First response	Extra gate
Low	Docs, tests-only, tiny refactor	4 business hours	1 reviewer
Medium	Feature behind flag, small API	1 business day	Owner + 1 reviewer
High	Auth, payments, infra, migrations, PII	2 business hours	Owner + senior + security ตามกรณี
Agent-authored	PR ใด ๆ ที่เปิดโดย agent	2 business hours	Named human owner + shepherd

6. Recommended Hard Gates (Platform Implementation)

```
if provenance in ["ai-assisted", "agent"]:  
    require_constitution_section_in_pr()  
    require_no_undeclared_dependency_changes()  
    if ai_percentage >= 0.15 and has_high_severity_findings:  
        fail("AI% ≥ 15% + high-severity findings")  
    if ai_percentage >= 0.40:  
        require_second_reviewer()  
    if touches_sensitive_paths(auth|pii|payments|infra):  
        require_traceability_note()  
        require_elevated_review()  
  
if provenance == "agent":  
    require_named_human_owner()  
    require_shepherd_approval()
```

7. Exception Path

Temporary exception ต่อ gate ใด ๆ ข้างต้นต้อง:

- ขอเป็นลายลักษณ์อักษรถึง AI Governance Lead
- มี time-box (สูงสุด 14 วัน เว้นแต่ต่ออายุ)
- บันทึกใน exception register
- แสดงเป็น label บน PR (exception:ai-gate-YYYYMMDD)

Personal consumer account ยังคงถูกห้ามสำหรับ company source หรือ confidential data; ไม่มี exception path สำหรับกฎนี้

8. Metrics ที่ต้องติดตาม (อย่างน้อยรายไตรมาส)

- สัดส่วน PR ที่มี provenance label ถูกต้อง
- Constitution compliance pass rate ในการ submit ครั้งแรก
- อัตรา undeclared dependency change
- Mean time to merge แยกตาม provenance + tier
- Post-merge defect / vuln แยกตาม provenance
- จำนวน active exception และ shadow-tool finding

End of CI Gates v1.0